

**CS-AML**

# **Frontend Architecture & State Management Specification**

Version 0.1.2

Approved Internal Specification Baseline

2026-10-09 · tag v0.1.2-spec

Civil Society Anti-Money Laundering & Financial Intelligence Framework

Generated from the canonical Markdown source. The Markdown file in the repository remains authoritative; change tags such as `[v0.1.x · ...]` are part of the traceability record.

# Contents

|                                                     |           |
|-----------------------------------------------------|-----------|
| <b>Document Control</b>                             | <b>3</b>  |
| <b>1. Scope and Non-Goals</b>                       | <b>4</b>  |
| <b>2. Architecture Principles</b>                   | <b>4</b>  |
| <b>3. Reference Frontend Stack</b>                  | <b>4</b>  |
| <b>4. Application Module Architecture</b>           | <b>5</b>  |
| <b>5. Routing and Navigation State</b>              | <b>6</b>  |
| <b>6. State Taxonomy and Ownership</b>              | <b>6</b>  |
| <b>7. Server-State Management</b>                   | <b>7</b>  |
| <b>8. Mutation and Concurrency Model</b>            | <b>7</b>  |
| <b>9. Form Architecture</b>                         | <b>8</b>  |
| <b>10. Authorization-Aware Rendering</b>            | <b>9</b>  |
| <b>11. Error and Recovery Architecture</b>          | <b>9</b>  |
| <b>12. Visualization State Management</b>           | <b>10</b> |
| <b>13. Search and Filter State</b>                  | <b>10</b> |
| <b>14. Session, Authentication and Logout</b>       | <b>10</b> |
| <b>15. Component and Feature Composition</b>        | <b>11</b> |
| <b>16. Performance and Rendering Strategy</b>       | <b>11</b> |
| <b>17. Accessibility Architecture</b>               | <b>11</b> |
| <b>18. Frontend Security Requirements</b>           | <b>12</b> |
| <b>19. Testing Strategy</b>                         | <b>12</b> |
| <b>20. Observability and Telemetry</b>              | <b>12</b> |
| <b>21. Frontend Configuration and Feature Flags</b> | <b>12</b> |
| <b>22. Screen-to-Feature Ownership Examples</b>     | <b>13</b> |
| <b>23. Frontend Definition of Done</b>              | <b>13</b> |
| <b>24. Architecture Decision Baseline</b>           | <b>14</b> |
| <b>Annex A — State Ownership Decision Tree</b>      | <b>14</b> |
| <b>Annex B — Frontend Review Checklist</b>          | <b>14</b> |

CS-AML  
Frontend Architecture & State Management Specification

Version 0.1.2

Document status — v0.1.2

Version: 0.1.2 — Approved Internal Specification Baseline (2026-10-09, tag v0.1.2-spec). Supersedes v0.1.1 (2026-10-08, tag v0.1.1-spec). [v0.1.2]

Supersedes: CS-AML Frontend Architecture & State Management Specification v0.1. The DOCX/PDF files in this repository are the unchanged v0.1 baseline (legacy); this Markdown file is the canonical source.

Validation: approved by the product owner as the internal specification baseline on 2026-10-08 (v0.1.1) and 2026-10-09 (v0.1.2; decision register and release gates in CHANGELOG.md). The v0.1.2 changes come from change requests raised while implementing increments I1-I4; this is not an independent audit. Acceptance criteria in this document are targets, not evidence that tests have passed.

CS-AML is not an external standard or certification. References to FATF, Wolfsberg, PPATK, UNODC or other bodies do not imply their endorsement.

Changes in 0.1.1: see CHANGELOG.md at the repository root (audit findings A01-A16).

Changes in 0.1.2: change requests CR-I1-01...CR-I4-14 approved by the product owner on 2026-10-09 (CHANGELOG.md, section v0.1.2). Each change is tagged \*[v0.1.2 · CR-xx-yy]\*.

Purpose

Proposed normative frontend architecture baseline (draft for review) for the CS-AML MVP. [v0.1.1 · A01] It defines frontend module boundaries, routing, state ownership, server-state synchronization, form and visualization state, authorization-aware rendering, concurrency handling, error recovery, accessibility, testing and frontend delivery conventions.

Core architecture axiom

Frontend state SHALL preserve canonical server truth, workflow versioning, permission boundaries and analytical uncertainty. The client SHALL NOT manufacture durable truth by promoting local, cached, inferred or visualization-only state into canonical state.

Status: Proposed normative frontend implementation baseline for MVP 0.1 (draft for review) [v0.1.1 · A01]

Dependencies: SRS v0.1.2 · Technical Stack v0.1.2 · API Specification v0.1.2 · UX v0.1.1 · IA v0.1.1 · Screen Inventory v0.1.1 · Wireframe v0.1.1 · UI Design System v0.1.2 · High-Fidelity UI v0.1.1 · Storybook (Component Inventory) v0.1.1 (Markdown, Documents/\*\_v0.1.1.md) [v0.1.1 · A01]

Document Control

| Attribute        | Value                                                                                                                                                                      |
|------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Document ID      | CSAML-FEARCH-0.1                                                                                                                                                           |
| Version          | 0.1.2 [v0.1.2]                                                                                                                                                             |
| Status           | Approved Internal Specification Baseline (2026-10-09, tag v0.1.2-spec) [v0.1.1 · A01]                                                                                      |
| Primary audience | Frontend Engineer, UX Engineer, Tech Lead, QA, Security Reviewer                                                                                                           |
| Reference stack  | React 19 + TypeScript + Vite + Tailwind CSS 4 + shared Storybook design system                                                                                             |
| API assumption   | Versioned same-origin REST API (/api/v1) with server-side BFF session; canonical authorization and validation remain server-side (API Specification v0.1.2) [v0.1.1 · A11] |
| Normative verbs  | SHALL / MUST / SHOULD / MAY                                                                                                                                                |

# 1. Scope and Non-Goals

This specification defines the frontend application architecture for the CS-AML MVP. It translates the screen and component specifications (draft for review) into implementation boundaries and state-management rules. It does not define backend business logic, canonical data schemas, authorization policy decisions, or API endpoint payloads; those are owned by backend specifications and the separate API Specification. *[v0.1.1 · A01]*

| In scope                                                                                                                                                                                        | Out of scope                                                                                          |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------|
| Feature-module organization, routing, data fetching, cache ownership, local state, forms, optimistic updates, concurrency, error handling, authorization-aware UI, visualization state, testing | Database model, server-side policy engine, evidence storage implementation, backend transaction rules |
| Frontend adaptation of canonical analytical semantics                                                                                                                                           | New analytical semantics not present in framework/data model                                          |
| Client security behavior and non-leakage rules                                                                                                                                                  | Treating UI hiding as an authorization control                                                        |

## Security boundary

Hiding a control or object in the UI is a usability measure, not an authorization decision. Every protected read or mutation SHALL remain authorized and validated by the API.

# 2. Architecture Principles

| ID     | Principle                        | Requirement                                                                                                                        |
|--------|----------------------------------|------------------------------------------------------------------------------------------------------------------------------------|
| FE-P01 | Server truth first               | Canonical objects, permissions, versions, approvals and audit-relevant state originate from server responses.                      |
| FE-P02 | State by ownership               | Server state, form state, navigation state, workflow state, visualization state and ephemeral UI state SHALL have distinct owners. |
| FE-P03 | URL is durable navigation state  | Object IDs, case context, active tabs, filters and shareable search context SHOULD live in URL state where safe.                   |
| FE-P04 | No monolithic global store       | A single application-wide mutable store SHALL NOT become the default home for all state.                                           |
| FE-P05 | Permission-aware by construction | Components receive authorized data; restricted metadata SHALL not be cached or rendered merely because a route was guessed.        |
| FE-P06 | Version-aware editing            | Editable canonical resources SHALL detect stale versions and prevent silent overwrite.                                             |
| FE-P07 | Derived views stay derived       | Graph layouts, timeline positions and view filters SHALL NOT silently mutate canonical relationships, events or value flows.       |
| FE-P08 | Uncertainty preserved            | Claim, fact, candidate, disputed, unknown and flow-class semantics persist through cache, form, visualization and export preview.  |
| FE-P09 | Recover locally                  | Component/feature failures SHOULD degrade locally before forcing a whole-app failure.                                              |
| FE-P10 | Accessible state                 | State changes, validation, loading and errors are exposed to keyboard and assistive technology.                                    |

# 3. Reference Frontend Stack

| Concern | Reference                               | Rule                                                                                        |
|---------|-----------------------------------------|---------------------------------------------------------------------------------------------|
| Runtime | React 19 + TypeScript                   | Strict TypeScript SHALL be enabled; any is exceptional and justified.                       |
| Build   | Vite                                    | Environment variables exposed to browser are explicitly allowlisted.                        |
| Styling | Tailwind CSS 4 + semantic CSS variables | Feature code consumes semantic tokens; raw status colors are prohibited where tokens exist. |
| Routing | React Router or equivalent              | Routes use stable canonical IDs; case context is explicit.                                  |

| Concern       | Reference                                                                                                                                                                                                                                                                                       | Rule                                                                                                                                                    |
|---------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------|
| Server state  | TanStack Query or equivalent                                                                                                                                                                                                                                                                    | Remote cache, invalidation, deduplication and mutation lifecycle are centralized here.                                                                  |
| Forms         | React Hook Form + schema validation or equivalent                                                                                                                                                                                                                                               | Form state stays local to form boundary; server validation is mapped back to fields.                                                                    |
| Schema types  | TypeScript client/types generated from contracts/openapi.yaml (OpenAPI 3.1; v0.1.2 covers the P0 slice plus the merged I3/I4 operations — assets, events/timeline, value-flow view, case graph, typologies, indicators, matches, hypothesis matrix, gaps — open items in API Specification §28) | Handwritten duplicate DTO types SHOULD be minimized; enum types use the UPPER_SNAKE_CASE wire values. [v0.1.1 · A09, A11] [v0.1.2 · CR-I3-01, CR-I4-01] |
| Visualization | Cytoscape.js + approved timeline/value-flow primitives                                                                                                                                                                                                                                          | Visualization state remains non-canonical.                                                                                                              |
| Storybook     | Storybook                                                                                                                                                                                                                                                                                       | Shared components and compound patterns require stories/test coverage.                                                                                  |
| Tests         | Vitest/Jest + Testing Library + Playwright                                                                                                                                                                                                                                                      | Behavior first; implementation-detail tests discouraged.                                                                                                |

## 4. Application Module Architecture

```

frontend/
  src/
    app/
      router/
      providers/
      error-boundaries/
    features/
      cases/
      evidence/
      entities/
      relationships/
      assets/
      timeline/
      valueflows/
      typologies/
      hypotheses/
      assessments/
      search/
      graph/
      products/
      reviews/
      dissemination/
      administration/
      audit/
    shared/
      api/
      auth/
      components/
      design-system/
      hooks/
      types/
      utils/
    test/

```

| Layer              | May depend on                                               | SHALL NOT depend on                                  |
|--------------------|-------------------------------------------------------------|------------------------------------------------------|
| app                | features, shared                                            | Feature internals via deep imports                   |
| feature            | shared, explicitly published contracts from another feature | Another feature's private components/store internals |
| shared API/auth    | generic infrastructure                                      | Feature UI                                           |
| design-system      | tokens, generic utilities                                   | Case/entity/business-specific behavior               |
| screen composition | feature public components, design system                    | Backend implementation details                       |

### Boundary rule

Cross-feature imports SHOULD use explicit public barrels/contracts. If two features repeatedly depend on the same domain presentation primitive, promote that primitive deliberately rather than creating circular imports.

## 5. Routing and Navigation State

```
/cases
/cases/:caseId/overview
/cases/:caseId/evidence/:evidenceId
/entities/:entityId?case=:caseId
/analysis/value-flows?case=:caseId
/products/:productId/review
/search?q=...&type=entity&case=...
```

| State                        | URL?                                      | Reason                                                               |
|------------------------------|-------------------------------------------|----------------------------------------------------------------------|
| Canonical object ID          | YES                                       | Deep-linkable identity.                                              |
| Case context                 | YES where relevant                        | Same entity may be opened inside different authorized case contexts. |
| Primary tab/section          | YES                                       | Back/forward navigation and shareable context.                       |
| Search query/facets          | YES unless sensitive query policy forbids | Reproducibility and navigation.                                      |
| Inspector open/closed        | Usually NO                                | Ephemeral view state.                                                |
| Unsaved form values          | NO                                        | Sensitive local state; do not leak into history/URL.                 |
| Graph viewport coordinates   | Usually NO                                | Derived visualization state; MAY persist as named saved view later.  |
| Protected-source identifiers | NO in ordinary route/query strings        | Avoid browser history/log leakage.                                   |

## 6. State Taxonomy and Ownership

| State class         | Examples                                                                                                                                                    | Owner                                         | Persistence                                                                                                                                                                                                     |
|---------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Server state        | Case, entity, evidence metadata, assessment version, review status                                                                                          | Query/cache layer backed by API               | Remote canonical; client cache ephemeral                                                                                                                                                                        |
| Form state          | Unsaved charter fields, hypothesis edit, relationship editor                                                                                                | Form boundary                                 | Memory; optional safe draft policy only                                                                                                                                                                         |
| Navigation state    | Route, case context, active tab, filters                                                                                                                    | Router/URL                                    | Browser history                                                                                                                                                                                                 |
| Workflow UI state   | Wizard step, review panel state                                                                                                                             | Feature component                             | Memory; derive from server when material                                                                                                                                                                        |
| Visualization state | Selected graph nodes, zoom, hidden layers, timeline scale                                                                                                   | Visualization controller                      | Memory; optional saved view, never canonical relationship truth                                                                                                                                                 |
| Ephemeral UI state  | Modal open, tooltip, toast, drawer                                                                                                                          | Local component                               | Memory                                                                                                                                                                                                          |
| Session/auth state  | Authenticated principal, username (display only), session expiry, coarse capabilities and csrf_token (from GET /auth/session) [v0.1.2 · CR-I1-03, CR-I1-07] | Auth provider                                 | Memory only; the HttpOnly session cookie is not readable by JavaScript and no tokens exist in the browser; the CSRF token is held in memory only and there is no CSRF cookie [v0.1.1 · A11] [v0.1.2 · CR-I1-03] |
| Preference state    | Density, reduced motion, column visibility                                                                                                                  | Preference service/ local storage if approved | Local or server preference; no sensitive case content                                                                                                                                                           |

### Hard rule

Canonical server state SHALL NOT be copied into a global mutable store merely to make it easy to access. Use normalized/query cache access and feature selectors instead. Duplicate copies create version drift and authorization leakage risk.

## 7. Server-State Management

- Every query key SHALL include all dimensions that materially change authorization or representation, including canonical object ID, case context where relevant, and relevant filters.
- Cache entries SHALL be invalidated or updated after successful canonical mutations according to explicit mutation contracts.
- Unauthorized/forbidden responses SHALL not be cached as if they were ordinary empty data.
- Query retries SHOULD be disabled or limited for 401/403/404 non-disclosing authorization outcomes. Mutations SHALL NOT be automatically retried on 409, 412, 422 or 428; automatic retry of a high-impact command after a network failure SHALL reuse the same Idempotency-Key. [v0.1.1 · A04, A11]
- Background refetch MAY refresh read screens; editable screens require version-aware reconciliation before replacing user-visible data.
- Prefetch MAY be used for ordinary objects but SHALL NOT prefetch protected-source identity or RESTRICTED/SOURCE\_PROTECTED content without an explicit authorized task. [v0.1.1 · A08]
- Client caches SHALL be cleared on logout/session revocation (including a 401 after back-channel revocation) and SHOULD be scoped to the authenticated principal. [v0.1.1 · A11]

| Query example                            | Key shape                                                                                                                         |
|------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------|
| Case overview                            | ["case", caseId, "overview"]                                                                                                      |
| Entity detail in case                    | ["entity", entityId, {caseId}]                                                                                                    |
| Evidence reader                          | ["evidence", evidencId, {caseId, version}]                                                                                        |
| Search                                   | ["search", {q,type,caseId,filters,page}]                                                                                          |
| Review product                           | ["product", productId, {version, mode:"review"}]                                                                                  |
| Case claims / facts (features/evidence)  | ["case", caseId, "claims", filters], ["case", caseId, "facts", filters] [v0.1.1 · C17]                                            |
| Claim / fact detail (features/evidence)  | ["claim", claimId], ["claim", claimId, "verification-decisions"], ["fact", factId], ["fact", factId, "dependents"] [v0.1.1 · C17] |
| Resolution decisions (features/entities) | ["entity", entityId, "resolution-decisions"], ["entity-match-candidates", filters] [v0.1.1 · C17]                                 |

## 8. Mutation and Concurrency Model

| Mutation type                              | Optimistic? | Rule                                                                                                                                                                                 |
|--------------------------------------------|-------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Low-impact preference                      | YES         | May update locally and rollback on failure.                                                                                                                                          |
| Task status                                | Conditional | Only if authorization and version conflicts are simple; failure visibly rolls back.                                                                                                  |
| Entity merge/unmerge                       | NO          | High-impact/reversible canonical action; wait for server result. Resolution decisions likewise; send expected_versions (§8 concurrency contract). [v0.1.1 · C17]                     |
| Claim verification decision / fact command | NO          | Append-only decision with reviewer-independence checks; wait for server result, then invalidate the claim or fact, its dependents and dependent assessments/products. [v0.1.1 · C17] |
| Evidence metadata affecting provenance     | NO          | Server validates integrity/version.                                                                                                                                                  |
| Assessment finalization                    | NO          | Requires server gate/version validation.                                                                                                                                             |
| Review approval/rejection                  | NO          | High-impact decision and independence checks.                                                                                                                                        |
| Dissemination approval/export              | NO          | Server authorization/audit must succeed first.                                                                                                                                       |
| Graph selection/layout                     | Local only  | Not a canonical mutation.                                                                                                                                                            |

**Concurrency contract** [v0.1.1 · A04]

Editable canonical resources carry `record_version`, returned as ETag: "`<record_version>`" on GET. Every mutation of a versioned resource SHALL send If-Match: "`<record_version>`" from the version the user is editing. Exception: multi-entity commands (entity merge, unmerge, POST `/resolution-decisions`, match-candidate decisions) send no If-Match; they send a body map `expected_versions`: `{<entityId>: <record_version>}` built from the versions of every subject entity shown to the user (API Specification §10, §14). [v0.1.1 · C03] The frontend SHALL NOT silently overwrite the newer server version. Response mapping:

| Response                    | Frontend behavior                                                                                                                                                                                                                                                                                                                                                                                                                                       |
|-----------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 412 PRECONDITION_FAILED     | "Record changed" recovery: keep the user's unsaved edits, show <code>details.current_record_version</code> , offer compare/reload/re-apply. For multi-entity commands the error carries <code>details.current_record_versions</code> (map of <code>entityId</code> → current <code>record_version</code> ): identify every changed entity, refetch them, and ask the user to re-confirm the merge/decision against the current versions. [v0.1.1 · C03] |
| 409 STATE_CONFLICT          | Workflow message explaining the state that blocks the action (e.g. gate not satisfied, already finalized); refetch the object state; no compare/merge flow.                                                                                                                                                                                                                                                                                             |
| 428 PRECONDITION_REQUIRED   | Client bug (missing If-Match, or missing/incomplete <code>expected_versions</code> [v0.1.1 · C03]): generic error with correlation ID, reported to telemetry; never shown as a user conflict.                                                                                                                                                                                                                                                           |
| 409 IDEMPOTENCY_IN_PROGRESS | Wait per Retry-After and poll/retry with the same key.                                                                                                                                                                                                                                                                                                                                                                                                  |
| 422 IDEMPOTENCY_KEY_REUSED  | Client bug: a key was reused with a different payload.                                                                                                                                                                                                                                                                                                                                                                                                  |

The v0.1 error code `VERSION_CONFLICT` is retired and SHALL NOT be mapped.

## 9. Form Architecture

- Forms SHALL use client-side schema validation for immediate feedback and server-side validation as authority.
- Unknown, null, approximate and zero SHALL remain distinct values where the domain model distinguishes them.
- Unsaved changes SHALL trigger safe-navigation protection for material forms.
- Form submission SHALL preserve field-level server errors and non-field errors.
- High-impact forms SHALL include explicit review summary before final action where defined by UX.
- Dynamic controlled-vocabulary fields SHALL retain term IDs and display labels; labels alone are not canonical values.
- Controlled enumerations are submitted and stored in client state as `UPPER_SNAKE_CASE` wire values (Data Model Annex A registry), e.g. `flow_class DIRECT/DOCUMENTED/RECONSTRUCTED/HYPOTHETICAL`; display labels are separate and translatable. [v0.1.1 · A09]
- `confidence.level INSUFFICIENT_BASIS` SHALL be rendered as its own neutral state (not as a level below Low, not as adverse, not as empty). Forms, sorting, filters and export previews SHALL NOT convert it to Low, null, zero, or drop it; a null level is shown as "not yet assessed" and is allowed only on drafts. Rationale is required for every level. [v0.1.1 · A09]
- Protected-source identity SHALL not be auto-filled into ordinary evidence or export forms.



| Form family           | Draft behavior                                                                                                  |
|-----------------------|-----------------------------------------------------------------------------------------------------------------|
| Case/charter          | Local unsaved state; server version after save.                                                                 |
| Evidence upload       | Upload session state; failed upload does not create completed evidence.                                         |
| Entity/relationship   | Local edit; canonical mutation on save.                                                                         |
| Hypothesis/assessment | Local edit + optional explicit server draft version; no invisible autosave that changes audit-relevant content. |
| Product editor        | Versioned draft; autosave MAY be used if server-side version/audit semantics are explicit.                      |
| Review/dissemination  | No optimistic finalization; server response authoritative.                                                      |

## 10. Authorization-Aware Rendering

| Pattern               | Requirement                                                                                                                                                                                                                                                                                             |
|-----------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Capability check      | UI MAY use server-provided capabilities to show/disable actions.                                                                                                                                                                                                                                        |
| Object access         | No component SHALL infer access solely from role name; object/case policy matters.                                                                                                                                                                                                                      |
| Non-disclosing denial | A 404/403 policy response SHALL map to the approved non-leaking system state.                                                                                                                                                                                                                           |
| Protected source      | Protected-source identity components SHALL exist in separately permissioned feature boundary and SHALL not be imported into ordinary evidence screens.                                                                                                                                                  |
| Export preview        | Only server-authorized export candidates are rendered as selectable.                                                                                                                                                                                                                                    |
| Counts/facets         | Counts returned by API are treated as already permission-filtered; frontend SHALL not reconstruct hidden totals.                                                                                                                                                                                        |
| Classification        | Render the five levels from wire values PUBLIC, INTERNAL, SENSITIVE, RESTRICTED, SOURCE_PROTECTED (labels Public ... Source-protected) together with access labels. An unknown or missing classification value SHALL render as restricted (fail closed), never default to Public. <i>[v0.1.1 · A08]</i> |

## 11. Error and Recovery Architecture

| Failure class                                   | UI behavior                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
|-------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Network/transient                               | Local retry with clear status; preserve safe unsaved state where feasible.                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Authentication expired                          | On 401, suspend protected work and re-authenticate via GET /auth/login; do not discard local form without warning where secure recovery is possible. <i>[v0.1.1 · A11]</i>                                                                                                                                                                                                                                                                                                                              |
| Authorization changed                           | Remove restricted cached content and transition to non-disclosing access state.                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Validation                                      | Field/non-field errors near source; no generic toast-only failure.                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Concurrency conflict (412 PRECONDITION_FAILED)  | Open "record changed" compare/reload/resolve flow; never auto-force overwrite. <i>[v0.1.1 · A04]</i>                                                                                                                                                                                                                                                                                                                                                                                                    |
| Workflow state conflict (409 STATE_CONFLICT)    | Show workflow message and refreshed state; no compare flow. <i>[v0.1.1 · A04]</i><br>Known details.reason values are rendered as explained states with the next action: COMPETING_HYPOTHESES_REQUIRED (list details.hypothesis_refs; add a competing hypothesis before finalizing), REVIEW_REQUIRED (a dependency changed; the draft needs review before finalization), DISCONFIRMATION_REQUIRED (record a disconfirming search before review approval). <i>[v0.1.2 · CR-I4-08, CR-I4-10, CR-I4-11]</i> |
| Missing precondition (428) / CSRF failure (403) | Treat as client defect: generic error with correlation ID; for CSRF, refresh the token via session bootstrap once before reporting. <i>[v0.1.1 · A04, A11]</i>                                                                                                                                                                                                                                                                                                                                          |
| Integrity warning                               | Blocking error treatment for evidence integrity issue.                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Partial feature failure                         | Local error boundary keeps surrounding case workspace usable.                                                                                                                                                                                                                                                                                                                                                                                                                                           |

| Failure class             | UI behavior                                                                              |
|---------------------------|------------------------------------------------------------------------------------------|
| Fatal application failure | Global recovery boundary with correlation ID; no sensitive payload in error display/log. |

## 12. Visualization State Management

| Domain            | Canonical state                             | Frontend-only state                                                   |
|-------------------|---------------------------------------------|-----------------------------------------------------------------------|
| Graph             | Entity/Relationship/Asset/ValueFlow objects | node positions, selection, zoom, hidden edge classes, inspector state |
| Timeline          | Event records and temporal precision        | scale, viewport, filters, expanded cards                              |
| Value Flow        | ValueFlow/legs/class/evidence               | canvas layout, selected leg, comparison overlays                      |
| Hypothesis matrix | Hypothesis/evidence link disposition        | sorting, collapsed rows, temporary filter                             |
| Evidence reader   | Evidence/Extract objects                    | page viewport, zoom, transient selection before extract save          |

### Derived-state rule

Layout algorithms, centrality calculations, path highlighting and client-side clustering MAY assist navigation, but SHALL remain visibly derived and SHALL NOT create canonical relationships, risk labels or adverse assessment state.

## 13. Search and Filter State

- Global search query and approved facets SHOULD be URL-addressable.
- Facet counts are server-provided permission-filtered values.
- Debounced queries SHALL be cancellable to avoid displaying stale results after a newer query completes.
- Sensitive query strings MAY require history/logging safeguards; protected-source identity SHALL not be exposed through ordinary global search.
- Search results SHALL display canonical object type/status and context without manufacturing analytical priority from ranking position.

## 14. Session, Authentication and Logout

- Browser authentication is a server-side session (BFF) as defined in API Specification v0.1.2 §4. The frontend is not an OIDC client: it holds no client ID/secret, never receives access, refresh or ID tokens, and SHALL NOT send Authorization: Bearer. *[v0.1.1 · A11]*
- Login: navigate the browser to GET /auth/login (full-page redirect); the backend completes GET /auth/callback and sets the \_\_Host-csaml\_session cookie (HttpOnly, Secure, SameSite=Lax, Path=/). *[v0.1.1 · A11]*
- Bootstrap: on app start and after login, call GET /auth/session to obtain principal, session expiry and coarse capabilities; 401 means unauthenticated. *[v0.1.1 · A11]* The same response delivers csrf\_token (kept in memory, sent as X-CSRFToken on every unsafe method) and username for the app shell; on a 403 CSRF failure the client re-bootstraps the session once and retries before reporting. *[v0.1.2 · CR-11-03, CR-11-07]*
- CSRF: every unsafe request (POST/PUT/PATCH/DELETE) SHALL send the Django CSRF token in the X-CSRFToken header. All API calls are same-origin (/api/v1) with credentials included; no cross-origin API calls. *[v0.1.1 · A11]*

- Logout: POST /auth/logout as a top-level form submission (application/x-www-form-urlencoded, CSRF token in the csrfmiddlewaretoken field), not fetch(), because the 303 to the IdP end-session endpoint is cross-origin and could not be followed by fetch(); clear query caches, feature state and sensitive in-memory state before submitting. [v0.1.2 · CR-11-04] The same clearing SHALL happen on user switch, on any 401 indicating session expiry or revocation (including Keycloak back-channel logout), and on a GET /auth/session principal change. [v0.1.1 · A11]
- Idle/session expiry behavior SHALL provide clear re-authentication path.
- Browser storage SHALL not contain raw evidence content, protected-source identity or any authentication token. [v0.1.1 · A11]
- Multi-tab session expiry SHOULD converge safely without preserving stale privileged UI.

## 15. Component and Feature Composition

| Layer             | Examples                                                       | State rule                                                              |
|-------------------|----------------------------------------------------------------|-------------------------------------------------------------------------|
| Design system     | Button, DataGrid, Badge, ClassificationBanner                  | No business fetching; presentational/interaction state only.            |
| Domain shared     | EvidenceCitation, ProvenanceTrail, FlowClassBadge, EntityBlock | Receives typed domain props; no screen-specific navigation assumptions. |
| Feature component | EntityMatchCompare, HypothesisMatrix                           | May own feature queries/mutations and local feature state.              |
| Screen container  | SCR-ENT-005, SCR-HYP-001                                       | Coordinates route context, feature components, error/loading states.    |
| App shell         | Header, primary nav, session                                   | Owns global navigation/session only.                                    |

## 16. Performance and Rendering Strategy

| Concern           | Requirement                                                                                                                 |
|-------------------|-----------------------------------------------------------------------------------------------------------------------------|
| Route splitting   | Feature routes SHOULD be code-split to reduce initial bundle.                                                               |
| Large tables      | Use pagination/virtualization where measured data volume requires it; virtualization SHALL preserve keyboard/accessibility. |
| Graph             | Progressive rendering and node limits SHOULD be explicit; large graph failure SHALL degrade to list/filter tools.           |
| Evidence reader   | Stream/page-render rather than loading huge files wholly into memory where possible.                                        |
| Search            | Cancel stale requests; cache recent authorized queries briefly.                                                             |
| Re-render control | Memoization SHOULD follow measured cost, not blanket use.                                                                   |
| Bundle budget     | Critical route bundles SHOULD be monitored in CI with agreed thresholds.                                                    |

## 17. Accessibility Architecture

- Route changes SHALL move focus/announce context appropriately.
- Loading, error, save success and validation states SHALL be programmatically perceivable.
- Graph/timeline/value-flow views SHALL have an accessible list/table alternative that references the same canonical objects.
- Keyboard focus SHALL remain recoverable after modal/drawer close and after dynamic mutations.

- Reduced-motion preference SHALL apply to graph transitions and other animations.
- Virtualized tables SHALL retain semantics and keyboard navigation.

## 18. Frontend Security Requirements

| ID        | Requirement                                                                                                                                                        |
|-----------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| FE-SEC-01 | No authorization decision relies solely on hidden/disabled UI.                                                                                                     |
| FE-SEC-02 | Sensitive API errors SHALL be rendered using non-disclosing approved states.                                                                                       |
| FE-SEC-03 | No raw evidence/protected-source content in analytics, telemetry breadcrumbs or routine console logs.                                                              |
| FE-SEC-04 | External links from evidence SHOULD use safe rel/referrer behavior according to policy.                                                                            |
| FE-SEC-05 | HTML/markdown/user content SHALL be safely rendered; no unsanitized injection.                                                                                     |
| FE-SEC-06 | File previews SHALL be sandboxed/isolated as appropriate and not execute active content.                                                                           |
| FE-SEC-07 | Browser storage use for case-sensitive state requires explicit security review.                                                                                    |
| FE-SEC-08 | Logout/user switch clears sensitive caches and feature state.                                                                                                      |
| FE-SEC-09 | No authentication tokens in JavaScript-accessible memory or storage; no Authorization: Bearer from the browser; X-CSRFToken on every unsafe method. [v0.1.1 · A11] |

## 19. Testing Strategy

| Layer                   | Minimum tests                                                                                                                                            |
|-------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------|
| Design-system component | Storybook stories + interaction + accessibility + visual regression.                                                                                     |
| Feature component       | Behavior, permission variants, loading/error, domain-state semantics.                                                                                    |
| Data hooks              | Query keys, invalidation, mutation error mapping, conflict handling (412 / 409 / 428 mapping per §8), INSUFFICIENT_BASIS round-trip. [v0.1.1 · A04, A09] |
| Route/screen            | Critical happy path + permission denied + stale version + responsive smoke.                                                                              |
| End-to-end              | Case → evidence → entity → value flow → hypothesis → assessment → review → dissemination.                                                                |
| Security                | Direct route guesses, cached-data logout, hidden-action API bypass expectation, non-leaking denied states.                                               |
| Accessibility           | Keyboard, focus, announcements, graph/list alternatives.                                                                                                 |

## 20. Observability and Telemetry

- Frontend errors SHOULD carry correlation/request IDs when provided by API.
- Operational telemetry SHALL avoid case titles, evidence snippets, protected-source identities and free-text analytical content.
- Performance metrics MAY include route load, API latency categories, rendering time and error rate using non-sensitive identifiers.
- User analytics SHALL follow the privacy specification; no keystroke/session replay over sensitive investigation screens by default.

## 21. Frontend Configuration and Feature Flags

| Config                         | Rule                                                                                                                                                            |
|--------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------|
| API base URL                   | Build/deployment configuration; no hardcoded production URL.                                                                                                    |
| OIDC config                    | None in the browser bundle: OIDC client configuration lives server-side (BFF); the frontend only knows the same-origin /auth/* endpoints. <i>[v0.1.1 · A11]</i> |
| Feature flags                  | Server/environment policy is authoritative for high-risk features; client flag alone cannot enable API capability.                                              |
| Build metadata                 | Version/commit SHOULD be visible in diagnostics.                                                                                                                |
| Experimental graph/AI features | Disabled by default unless approved deployment policy enables them.                                                                                             |

## 22. Screen-to-Feature Ownership Examples

| Screen                                                         | Feature owner    | Primary state owners                                                                                                                                                        |
|----------------------------------------------------------------|------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| SCR-CASE-003                                                   | cases            | case server state; route caselid; local panel state                                                                                                                         |
| SCR-EVD-003                                                    | evidence         | evidence server state; reader viewport; extract draft form                                                                                                                  |
| SCR-ENT-005                                                    | entities         | candidate server state; compare UI state; merge mutation                                                                                                                    |
| SCR-EVD-004,<br>SCR-EVD-003,<br>SCR-SRC-002 (claims and facts) | evidence         | claims, facts, verification decisions and fact dependents server state; claim/fact forms; verification-decision and fact-command mutations (If-Match) <i>[v0.1.1 · C17]</i> |
| SCR-ENT-005,<br>SCR-ENT-006 (resolution decisions)             | entities         | resolution-decision history server state; merge/unmerge/ resolution-decision mutations (expected_versions, Idempotency-Key) <i>[v0.1.1 · C17]</i>                           |
| SCR-VAL-001                                                    | valueflows       | flow server state; filters in URL; canvas selection/layout local                                                                                                            |
| SCR-HYP-001                                                    | hypotheses       | hypothesis server state; matrix filters local; edits form state                                                                                                             |
| SCR-REV-002                                                    | reviews/products | product version server state; comment form; approval mutation                                                                                                               |
| SCR-DIS-002                                                    | dissemination    | authorized export candidates server state; selection form; export mutation                                                                                                  |

**Owners of claim, fact and resolution data.** *[v0.1.1 · C17]* features/evidence owns Claim, Fact and VerificationDecision server state (query keys in §7). A successful verification decision invalidates the claim; a fact command invalidates the fact, its dependents and the dependent assessments/products (whose review\_required may change). features/entities owns Resolution-Decision state (query keys in §7); a merge, unmerge or resolution decision invalidates every subject entity, its relationships and the candidate list. features/assessments and features/products read review\_required and render it with ANA-001 (review-required variant).

## 23. Frontend Definition of Done

| Area            | Done when                                                                                           |
|-----------------|-----------------------------------------------------------------------------------------------------|
| Architecture    | Feature is in correct module and does not create circular/private cross-feature dependencies.       |
| State ownership | Remote, form, route, visualization and ephemeral state have explicit owners.                        |
| Authorization   | Denied/changed permissions are handled without data leakage; server remains authoritative.          |
| Concurrency     | Editable canonical records handle stale versions safely.                                            |
| UI semantics    | Shared design-system/domain components preserve uncertainty/provenance semantics.                   |
| Accessibility   | Keyboard, focus and state announcements verified.                                                   |
| Tests           | Unit/integration/screen/E2E coverage appropriate to risk; Storybook coverage for shared components. |
| Security        | Sensitive content absent from logs/storage/telemetry beyond approved mechanisms.                    |
| Performance     | Critical route/render performance meets MVP thresholds.                                             |

| Area         | Done when                                                                                             |
|--------------|-------------------------------------------------------------------------------------------------------|
| Traceability | Screen IDs and SRS/feature references included in implementation issue/test metadata where practical. |

## 24. Architecture Decision Baseline

| Decision   | Baseline                                                                             |
|------------|--------------------------------------------------------------------------------------|
| FE-ADR-001 | Feature-oriented modular React application; no page-folder monolith.                 |
| FE-ADR-002 | TanStack Query-equivalent owns server state; no duplicate global canonical store.    |
| FE-ADR-003 | Form library owns unsaved form state; durable draft requires explicit server object. |
| FE-ADR-004 | React Router-equivalent owns shareable navigation/filter context.                    |
| FE-ADR-005 | Visualization controllers own layout/selection; graph layout is not canonical truth. |
| FE-ADR-006 | Shared component package/design system before feature-local duplicates.              |
| FE-ADR-007 | Version-aware mutations for canonical editable objects.                              |
| FE-ADR-008 | No offline-first evidence cache in MVP.                                              |

## Annex A — State Ownership Decision Tree

```

Is the value canonical or returned by API?
YES → Server/query state.
NO → Is it an unsaved user edit?
    YES → Form state.
    NO → Must it survive/share via URL/back button?
        YES → Router/URL state.
        NO → Is it visualization-only (selection/layout/zoom)?
            YES → Visualization controller state.
            NO → Is it transient UI chrome?
                YES → Local component state.
                NO → Define explicit feature ownership; do not default to global store.

```

## Annex B — Frontend Review Checklist

- No canonical object copied into unversioned global mutable state.
- Query key includes relevant case/context dimensions.
- Logout/user switch clears sensitive caches.
- 403/404 non-disclosing states handled correctly.
- Unknown/null/zero distinctions preserved.
- No optimistic high-impact approval/merge/dissemination.
- Stale-version conflict tested: 412 → "record changed" recovery; 409 → workflow message; 428 → client bug. [v0.1.1 · A04]
- Graph/timeline/value-flow derived state does not mutate canonical objects.
- Keyboard/focus/error/loading states tested.
- No protected-source content in ordinary browser storage or telemetry.